

Nombre: Luis Alberto Vargas Gonzalez

Fecha: 23/09/2025

Actividad y unidad: Unidad 2 A1. La seguridad de la información y sus servicios.

Clase: Ciberseguridad.

Maestría en Ciberseguridad.

1. Selección de industria y nombre de empresa.

Empresa Ficticia: "Energía Conectada (EnerCon)"

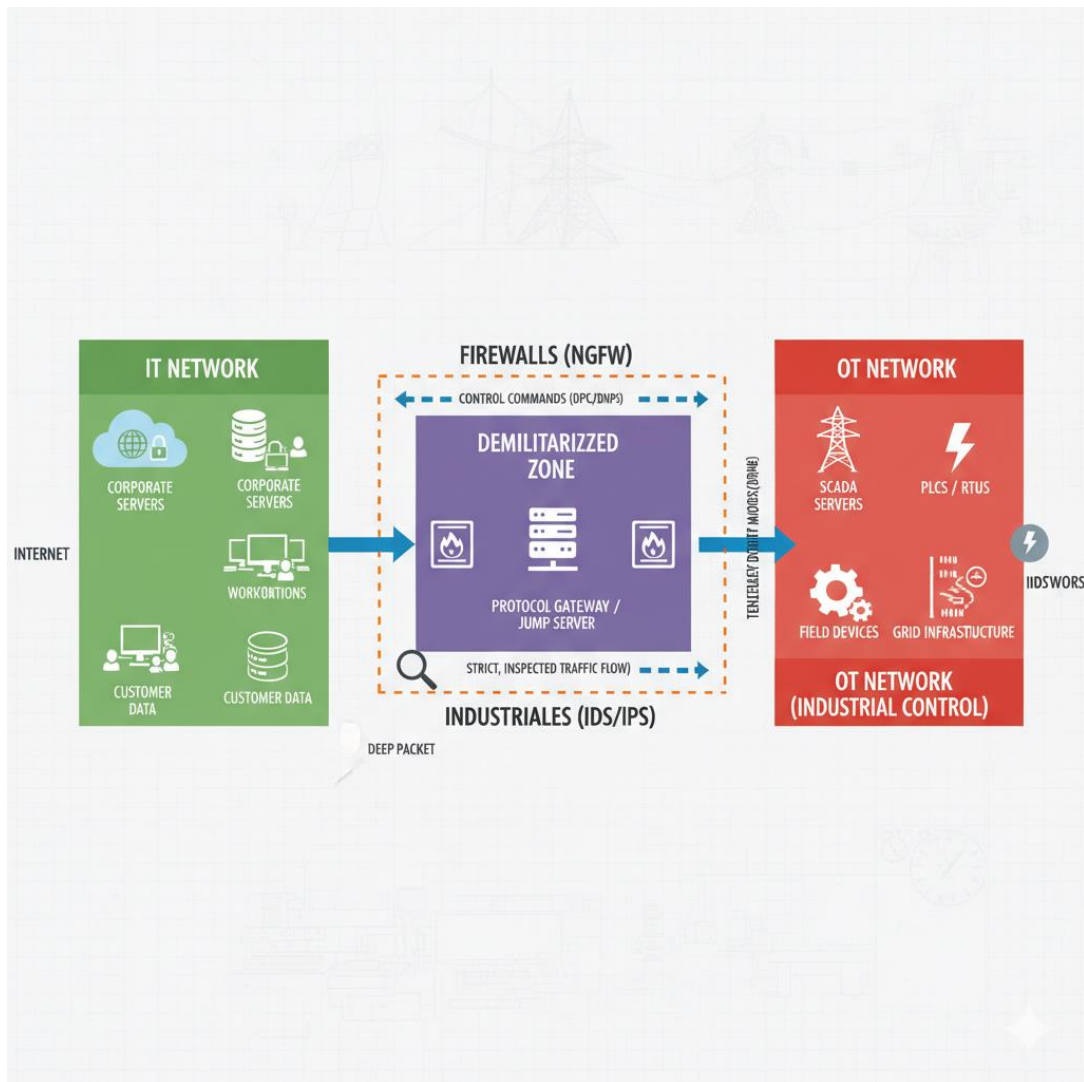
- **Perfil de la Empresa: EnerCon** es una compañía de energía eléctrica de gran envergadura que opera en varias regiones de México. Su modelo de negocio abarca toda la cadena de suministro eléctrico:
 - **Generación:** Opera una mezcla diversificada de plantas de energía, incluyendo ciclos combinados (gas natural), parques eólicos, plantas solares y una central hidroeléctrica.
 - **Transmisión:** Gestiona la red de alta tensión que transporta la electricidad desde las plantas de generación hasta las subestaciones principales.
 - **Distribución:** Se encarga de la red de media y baja tensión que lleva la electricidad desde las subestaciones hasta los clientes finales.
- **Segmentos de Clientes:** Atiende a una amplia gama de clientes, desde millones de hogares (clientes residenciales) hasta grandes corporaciones (clientes industriales) y entidades gubernamentales (hospitales, escuelas, infraestructura pública).
- **Infraestructura Tecnológica Clave:**
 - **Sistemas de Control Industrial (ICS) / SCADA:** Utiliza sistemas SCADA (Supervisión, Control y Adquisición de Datos) para monitorear y controlar en tiempo real las operaciones de generación, transmisión y distribución.
 - **Redes de TI Corporativas:** Mantiene una infraestructura de Tecnologías de la Información (TI) para la gestión empresarial (finanzas, recursos humanos, facturación, etc.).
 - **Redes de Tecnología Operacional (OT):** Redes especializadas que conectan los dispositivos físicos (sensores, actuadores, medidores inteligentes) en el campo. Es crucial entender que las redes de TI y OT, aunque históricamente separadas, están cada vez más interconectadas.

- **Infraestructura de Medición Avanzada (AMI):** Ha desplegado una red de medidores inteligentes que permiten la comunicación bidireccional con los clientes para la lectura remota del consumo y la gestión de la demanda.

2. Identificación de activos.

1. Activos de Tecnología Operacional (OT) y Sistemas de Control Industrial (ICS)

- **Datos de telemetría en tiempo real**
- **Comandos de control del sistema SCADA**
- **Firmware y configuración de Dispositivos Electrónicos Inteligentes (IEDs)**
- **Mapas de la red eléctrica y topología**



2. Activos de Información de Clientes, Medición y Pagos Digitales

- Base de datos de clientes (PII)
- Datos de consumo eléctrico (AMI)
- Información de facturación y pagos tradicionales
- Datos de Transacciones Digitales:  Información altamente sensible proveniente de la app móvil y el portal web de EnerCon. Esto incluye:
 - **Datos de Tarjetas de Crédito/Débito (TDD/TDC):** Números de tarjeta, fechas de vencimiento, códigos CVV (aunque idealmente no se almacenan, sí se procesan). Este tipo de información está regulada por estándares como **PCI DSS** (Payment Card Industry Data Security Standard).

- **Credenciales de acceso a la plataforma de pagos:** Nombres de usuario y contraseñas para el portal de clientes.
- **Historial de transacciones digitales:** Registros detallados de cada pago realizado a través de canales digitales.

3. Activos de Información Corporativa, Financiera y Estratégica

- **Planes de expansión y proyectos de infraestructura**
- **Propiedad intelectual** (diseños, algoritmos, etc.)
- **Informes financieros internos y proyecciones**
- **Información de Inversionistas y Mercado de Capitales:** Datos relacionados con la salud financiera de la empresa y su relación con los mercados.
 - **Base de datos de inversionistas:** Registros de entidades institucionales e individuos que poseen bonos o deuda de EnerCon. Incluye información de contacto y detalles de las tenencias.
 - **Comunicaciones confidenciales con inversionistas:** Informes no públicos, proyecciones financieras detalladas y estrategias que se comparten con inversionistas clave.
 - **Datos de análisis de mercado y estrategias de financiamiento:** Información sobre planes para emitir nueva deuda o acciones. Su filtración podría dar lugar a manipulación del mercado.
- **Planes de respuesta a incidentes y recuperación de desastres**

4. Activos de Recursos Humanos

- **Datos personales de empleados**
- **Credenciales de acceso y niveles de privilegio.**

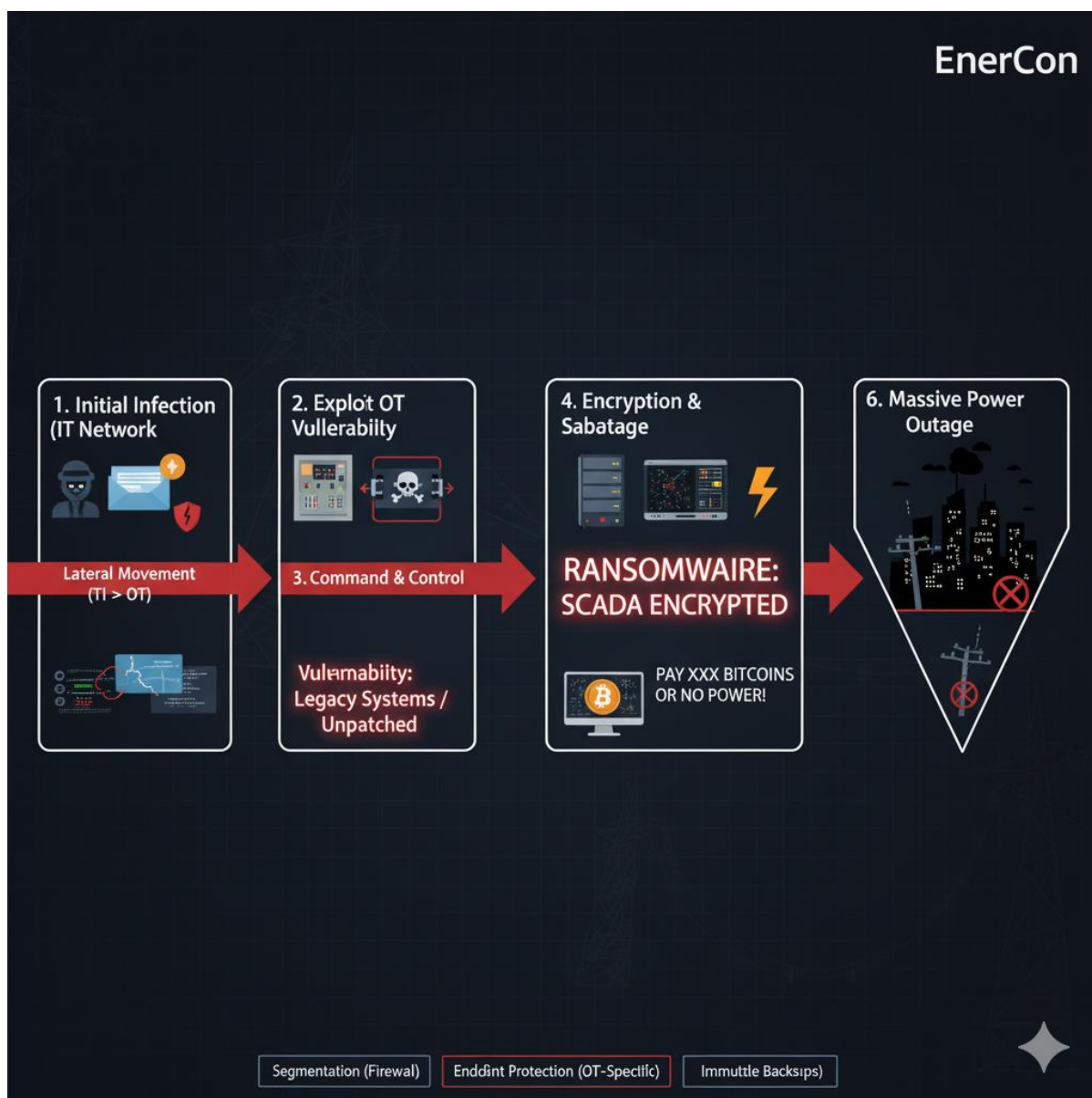
3. Evaluación de riesgos.

A. Amenazas Específicas para EnerCon

- **Ciberdelincuentes (Motivación Económica):** Grupos organizados que buscan ganancias a través del robo de datos de tarjetas de crédito (TDD/TDC), venta de datos personales (PII) en la dark web y, por supuesto, **ransomware**.
- **Actores de Estado-Nación (APTs):** Agentes patrocinados por gobiernos cuyo objetivo puede ser el espionaje (robar propiedad intelectual o planes de infraestructura) o el sabotaje para desestabilizar una región causando un apagón masivo. Son la amenaza más sofisticada.
- **Hactivistas:** Grupos que atacan por motivos ideológicos. Suelen buscar la interrupción del servicio para generar atención mediática, principalmente mediante ataques de **Denegación de Servicio Distribuido (DDoS)**.
- **Insiders (Amenazas Internas):** Empleados o contratistas que, ya sea por negligencia (ej. cayendo en un phishing) o con intención maliciosa, abusan de su acceso para robar información o sabotear sistemas.

B. Vulnerabilidades Clave de EnerCon

- **Convergencia TI/OT:** La conexión entre la red corporativa (TI) y la red de control industrial (OT) es una autopista para los atacantes. Un correo de phishing en la red de TI puede ser el punto de partida para llegar a los sistemas SCADA.
- **Sistemas OT Heredados (Legacy):** Muchos componentes de la red OT son antiguos, no fueron diseñados pensando en la ciberseguridad, y no pueden ser parcheados fácilmente sin detener las operaciones.
- **Superficie de Ataque Digital:** Las aplicaciones web y móviles para el pago de facturas son puntos de entrada expuestos a internet y vulnerables a ataques como la inyección de SQL o Cross-Site Scripting (XSS).
- **Falta de Segmentación de Red:** Si un atacante compromete un sistema, la falta de una segmentación estricta le permite moverse lateralmente con facilidad hacia activos más críticos.
- **Dependencia de la Cadena de Suministro:** El software o hardware de un proveedor podría venir con una vulnerabilidad o un troyano preinstalado.



C. Escenarios de Ataque, Probabilidad e Impacto

Aquí combinamos las amenazas y vulnerabilidades en los escenarios y algunos otros.

Escenario de ataque	Amenaza principal	Vulnerabilidad explotada	Probabilidad	Impacto (CIA)
---------------------	-------------------	--------------------------	--------------	---------------

1. Ransomware en la red OT/ICS	Ciberdelincuentes	Convergencia TI/OT, Phishing a un empleado	Media-Alta	C: Bajo, I:Crítico, A: Crítico.
<i>Descripción:</i> Un atacante cifra los servidores SCADA y las estaciones de los operadores. No se puede controlar el flujo de energía, forzando un apagón preventivo para evitar daños físicos. El impacto es masivo en la población y la industria.				
2. Fuga masiva de datos de TDD/TDC	Ciberdelincuentes	Vulnerabilidad en el sistema de pagos (Inyección SQL)	Alta	Crítico, I: Bajo, A: Bajo
<i>Descripción:</i> Se exfiltran los datos personales y de pago de millones de clientes. Conlleva a un daño reputacional severo, multas millonarias por incumplimiento de normativas (como PCI DSS y LFPDPPP) y				

pérdida de confianza.				
3. Ataque DDoS contra servicio a clientes	Hacktivistas	Insuficiente protección anti-DDoS en infraestructura web.	Media	C: Nulo I: Nulo A: ALTO
<i>Descripción:</i> El portal web y la app móvil quedan inaccesibles. Los clientes no pueden consultar su saldo ni pagar sus facturas, afectando la operación comercial y el flujo de caja de la empresa.				
4. Sabotaje por un APT	APT	Sistemas OT legacy, movimientos laterales.	Baja	C: Bajo I: CRÍTICO A: CRÍTICO
<i>Descripción:</i> Un atacante sofisticado se infiltra sigilosamente, aprende el funcionamiento de la red y manipula los controladores para causar un apagón en cascada y daño físico a la infraestructura (ej. sobrecarga de				

transformadores). Es el peor escenario posible.				
---	--	--	--	--

4. Aplicación de controles de seguridad.

Se propone una estrategia proactiva de **Defensa en profundidad**, Esto significa que crearemos múltiples capas de seguridad, de modo que si una falla, otra pueda contener la amenaza.

1. Controles para el Riesgo #1: Ransomware en la Red OT/ICS

El objetivo aquí es evitar que un atacante cruce de la red de TI a la red de OT y cause un apagón.

- **Segmentación Estricta de la Red (Integridad y Disponibilidad):**
 - **Control:** Implementar una **Zona Desmilitarizada (DMZ)** entre las redes de TI y OT utilizando firewalls de nueva generación (NGFW). Todo el tráfico entre TI y OT debe ser explícitamente autorizado e inspeccionado. Esto rompe la "autopista" directa para los atacantes.
 - **Pilar:** Preserva la **integridad y disponibilidad** de la red OT al aislarla de amenazas en la red corporativa.
- **Monitoreo de Seguridad de OT (Integridad y Disponibilidad):**

- **Control:** Desplegar una plataforma de monitoreo de red especializada en OT (como Dragos o Nozomi Networks). Estas herramientas entienden protocolos industriales (como Modbus, DNP3) y pueden detectar comportamientos anómalos, como un PLC recibiendo comandos no autorizados o un HMI comunicándose con un servidor desconocido.
- **Pilar:** Garantiza la **integridad** al detectar manipulaciones y la **disponibilidad** al alertar sobre posibles sabotajes.
- **Plan de Recuperación y Backups "Air-Gapped" (Disponibilidad):**
 - **Control:** Establecer un sistema robusto de copias de seguridad para todos los sistemas críticos de OT (servidores SCADA, configuraciones de IEDs, etc.). Es fundamental que estas copias estén "air-gapped", es decir, físicamente desconectadas de la red principal, para que el ransomware no pueda cifrarlas.
 - **Pilar:** Es el control definitivo para garantizar la **disponibilidad**. Si lo peor ocurre, permite restaurar las operaciones.

2. Controles para el Riesgo #2: Fuga Masiva de Datos de Clientes

El foco es proteger la información personal y financiera de los clientes en las plataformas digitales.

- **Cifrado de Datos en Reposo y en Tránsito (Confidencialidad):**
 - **Control:** Cifrar la base de datos de clientes utilizando tecnologías como Transparent Data Encryption (TDE). Además, forzar el uso de **TLS 1.3** (la última versión del protocolo de seguridad) para todas las comunicaciones entre los clientes (navegador/app) y los servidores de EnerCon.
 - **Pilar:** Es el control principal para asegurar la **confidencialidad**. Si los datos son robados, serán ilegibles.
- **Web Application Firewall (WAF) y Tokenización (Integridad y Confidencialidad):**
 - **Control:** Implementar un WAF para proteger el portal de pagos de ataques comunes (SQL Injection, XSS). Para los datos de tarjetas, se debe utilizar **tokenización** a través de una pasarela de pagos

certificada en **PCI DSS**. Esto significa que EnerCon no almacena los números de tarjeta, sino un "token" no sensible que representa esa tarjeta.

- **Pilar:** El WAF protege la **integridad** del portal y la tokenización refuerza radicalmente la **confidencialidad** de los datos de pago.

3. Controles para el Riesgo #3: Ataque DDoS

El objetivo es simple: mantener los servicios en línea.

- **Servicio de Mitigación de DDoS Basado en la Nube (Disponibilidad):**
 - **Control:** Contratar un servicio de un proveedor especializado (como Akamai o Cloudflare). Este servicio actúa como un "escudo" que absorbe y filtra el tráfico malicioso a gran escala antes de que llegue a la infraestructura de EnerCon.
 - **Pilar:** Un control puro de **disponibilidad**.

4. Controles Transversales (Fundamentales para Todos los Riesgos)

Estos controles elevan el nivel de madurez de la seguridad en toda la organización.

- **Gestión de Identidad y Acceso (IAM) con MFA (Autenticidad y Confidencialidad):**
 - **Control:** Implementar un modelo de **mínimo privilegio**, donde los empleados solo tengan acceso a lo estrictamente necesario para su trabajo. Exigir **Autenticación de Dos Factores (2FA/MFA)** para todo acceso a sistemas críticos, tanto en TI como en OT, y también para las cuentas de los clientes en el portal.
 - **Pilar:** Garantiza la **autenticidad** (sabemos que quien accede es quien dice ser) y protege la **confidencialidad**.
- **Programa de Concienciación y Capacitación Continua (Factor Humano):**
 - **Control:** Realizar campañas de simulación de phishing periódicas y obligatorias para todos los empleados. Capacitar al personal, especialmente a los operadores de OT, sobre las tácticas de ingeniería social.

- **Pilar:** Fortalece a la primera línea de defensa: las personas.

5. Análisis de impacto y costos.

Beneficios y Valor de Mitigar los Riesgos (El Costo de un Incidente)

Este punto no cambia, pero lo reforzamos con cifras. Según estudios (como el "Cost of a Data Breach Report" de IBM), el costo promedio de una brecha de datos en el sector energético es de millones de dólares. Un ataque de ransomware a infraestructura crítica puede superar fácilmente los **\$50 millones de dólares** en pérdidas totales. La inversión en defensa es para evitar estas cifras.

Costos Asociados a la Implementación de Controles (Estimaciones 2025)

Dividiremos los costos en Inversión Inicial (CAPEX) y Gastos Operativos Anuales (OPEX).

Control de seguridad	Tipo de costo	Costo estimado	Notas
1. Segmentación de red y firewalls TI/OT	CAPEX	250k-600k USD	Compra de un par de firewalls de grado industrial (e.g., Fortinet, Palo Alto) y las horas de consultoría especializada para el diseño e

			implementación segura.
2. Monitoreo de seguridad OT	OPEX	150k-400k USD	Licenciamiento de plataformas como Dragos o Nozomi. El precio se basa en la cantidad de activos de red a monitorear.
3. Backups Air-gapped	CAPEX	70K-150K USD	Inversión en servidores de backup, software (e.g., Veeam) y almacenamiento (posiblemente cinta LTO o almacenamiento inmutable en la nube).
4. Web Application Firewall (WAF)	OPEX	50K-120K USD	Asumiendo un servicio WAF basado en la nube (e.g., Cloudflare Enterprise, Imperva) que protege las aplicaciones web de EnerCon.
5. Servicio de mitigación DDoS	OPEX	60k-150k USD	Costo de un servicio "always-on" para proteger un ancho de banda significativo.
6. IAM y MFA	OPEX	80k-200k USD	Costo de una plataforma como Okta o Azure AD Premium P2,

			calculado por el número de empleados y clientes que usarán MFA.
7. Capacitaciones a empleados en phishing simulado	OPEX	20k-50k USD	Plataformas como KnowBe4. El costo es por empleado/año y es una de las inversiones más rentables en ciberseguridad.
8. Personal SOC	OPEX	300k-1M USD anual	Opción A (Externalizar): Un SOC Gestionado 24/7 puede costar de \$300k a \$600k. Opción B (Interno): Construir un SOC 24/7 requiere al menos 8-10 analistas, lo que, sumando salarios y tecnología SIEM, supera fácilmente el millón de dólares.

Balance Costo-Beneficio (Con Cifras)

- **Inversión Total Estimada (Primer Año):**
 - **CAPEX (Inversión Inicial):** ~\$320,000 - \$750,000
 - **OPEX (Gasto Anual):** ~\$660,000 - \$1,920,000 (usando la opción de SOC externalizado para el rango más bajo)
- **Conclusión:** EnerCon estaría considerando una inversión inicial de hasta **\$750,000 USD** y un presupuesto operativo anual de ciberseguridad de entre **\$1 y \$2 millones de USD** para implementar este programa. Si bien

parece una cifra elevada, palidece en comparación con el costo de un solo ataque exitoso a su red OT, que podría **superar los \$50 millones de dólares**, sin contar el daño reputacional y el impacto a la seguridad nacional. La inversión representa aproximadamente entre un **2% y un 4%** del costo potencial de un solo incidente catastrófico.

6. Plan de implementación.

El plan se estructura en cuatro fases trimestrales a lo largo de un año. La priorización se basa en obtener visibilidad y asegurar los perímetros primero (ganancias rápidas y de alto impacto), para luego pasar a controles más profundos y a la optimización.

Responsables Clave:

- **CISO (Chief Information Security Officer):** Patrocinador y máximo responsable del programa.
- **Gerente de Proyecto de Seguridad:** Responsable de la ejecución diaria del plan.
- **Líderes de TI, OT y Desarrollo:** Responsables de implementar los controles en sus respectivas áreas.

Fase 1: Fundación y Visibilidad (Mes 1 - 3)

Objetivo: Entender el terreno y establecer las defensas básicas.

1. **Kick-off del Proyecto y Formación del Equipo (Semana 1-2):**
 - a. **Acción:** Definir roles, responsabilidades y establecer la gobernanza del proyecto.
 - b. **Responsable:** CISO.
2. **Análisis de Brechas y Pruebas de Penetración (Semana 3-8):**

- a. **Acción:** Contratar a una firma externa para evaluar la seguridad de la red OT, las aplicaciones web y la red corporativa. Esto validará nuestras suposiciones de riesgo.
 - b. **Responsable:** Gerente de Proyecto.
- 3. Despliegue del Monitoreo de Red OT (Semana 6-12):**
- a. **Acción:** Instalar los sensores de la plataforma de monitoreo en modo pasivo. El objetivo inicial no es bloquear, sino aprender el comportamiento normal ("baseline") de la red industrial.
 - b. **Responsable:** Líder de OT.
- 4. Lanzamiento del Programa de Concienciación (Mes 3):**
- a. **Acción:** Realizar la primera campaña de capacitación en seguridad y la primera simulación de phishing para todos los empleados.
 - b. **Responsable:** CISO.

Fase 2: Fortalecimiento del Perímetro y Accesos (Mes 4 - 6)

Objetivo: Levantar los muros y controlar las puertas de acceso.

- 1. Implementación de la Segmentación TI/OT (Mes 4-5):**
- a. **Acción:** Desplegar y configurar los firewalls de grado industrial para crear la DMZ. Esta es la tarea más crítica y delicada de la fase.
 - b. **Responsable:** Líder de TI / Líder de OT.
- 2. Activación de Servicios en la Nube (WAF y Anti-DDoS) (Mes 4):**
- a. **Acción:** Poner en producción los servicios de WAF y mitigación de DDoS para proteger el portal de clientes.
 - b. **Responsable:** Líder de TI.
- 3. Despliegue de IAM y MFA para Administradores (Mes 5-6):**
- a. **Acción:** Implementar la solución de gestión de identidades y obligar el uso de MFA para todo el personal con acceso privilegiado.
 - b. **Responsable:** Líder de TI.

Fase 3: Protección de Datos y Resiliencia (Mes 7 - 9)

Objetivo: Asegurar las "joyas de la corona" y garantizar la capacidad de recuperación.

1. Implementación del Cifrado de Bases de Datos (Mes 7):

- a. **Acción:** Ejecutar el plan para cifrar las bases de datos que contienen información sensible de clientes.
- b. **Responsable:** Líder de Desarrollo / DBA.

2. Despliegue del Plan de Backups "Air-Gapped" para OT (Mes 8-9):

- a. **Acción:** Poner en marcha la solución de copias de seguridad desconectadas. Realizar las primeras pruebas completas de restauración.
- b. **Responsable:** Líder de OT.

3. Habilitación de MFA para Clientes (Mes 9):

- a. **Acción:** Ofrecer e incentivar el uso de MFA para todos los clientes en el portal de EnerCon.
- b. **Responsable:** Líder de Desarrollo.

Fase 4: Operacionalización y Mejora Continua (Mes 10 - 12)

Objetivo: Pasar de un proyecto a un proceso de seguridad maduro y sostenible.

1. Integración con el SOC (Centro de Operaciones de Seguridad) (Mes 10):

- a. **Acción:** Conectar todas las nuevas herramientas (Firewalls, WAF, Monitoreo OT) al SOC para un monitoreo y respuesta centralizados 24/7.
- b. **Responsable:** CISO.

2. Simulacros y Pruebas del Plan de Respuesta a Incidentes (Mes 11):

- a. **Acción:** Realizar ejercicios de simulación ("tabletop exercises") basados en los escenarios de riesgo (ransomware en OT, fuga de datos) con todos los equipos involucrados.
- b. **Responsable:** Gerente de Proyecto.

3. Revisión Anual y Planificación del Siguiete Ciclo (Mes 12):

- a. **Acción:** Evaluar el éxito del plan, medir KPIs (ej. reducción del tiempo de detección de amenazas) y planificar las nuevas iniciativas para el próximo año.
- b. **Responsable:** CISO.